Phishing Email Detection & Awareness System

Cybersecurity Internship — Task 2 | Security Awareness Report

What This Report Contains

Section 1	Phishing Threat Overview — What it is and why it works
Section 2	Email Sample Analysis — Full indicator breakdown with annotations
Section 3	Risk Classification — Safe / Suspicious / Phishing framework
Section 4	How the Attack Works — Plain-language explanation for employees
Section 5	Prevention Tips — Practical steps anyone can follow
Section 6	Do's & Don'ts — Quick-reference card for employees

SECTION 1

Phishing Threat Overview

Understanding the nature, scale, and mechanics of phishing attacks.

Phishing is a form of **social engineering** — a cyberattack that manipulates human psychology rather than exploiting software vulnerabilities. Attackers impersonate trusted entities such as banks, government agencies, or popular platforms to trick victims into surrendering sensitive information, clicking malicious links, or downloading malware.

91%	$4.9M	3 sec	1 in 5
of cyberattacks begin with a phishing email	average cost of a phishing breach (IBM 2023)	average time a user takes to click a fake link	employees will click a phishing link

Why Phishing Succeeds

Phishing exploits six core psychological triggers. Understanding these is the first step in building human-layer defence:

Fear	*""Your account will be permanently suspended.""* — Panic overrides rational judgment.
Urgency	*""Verify within 24 hours or lose access.""* — Time pressure prevents careful verification.
Authority	*""This is your bank's IT security team.""* — People instinctively comply with authority.
Curiosity	*""Your parcel delivery was attempted.""* — Triggers the need to find out more.
Trust	*"Email visually identical to a PayPal message."* — Brand mimicry bypasses suspicion.
Greed	*""You have been selected for a Rs. 10,000 reward.""* — Hope of reward clouds critical thinking.

SECTION 2

Email Sample Analysis

Detailed breakdown of a real-world phishing email — every indicator identified and explained.

Sample Email Under Analysis

From:	security@secure-account-verify.com
To:	user@company.com
Subject:	Urgent: Your Account Will Be Locked
Date:	Thursday, 10 April 2025, 02:14 AM
Body:	Dear User, We noticed suspicious activity on your account. To avoid account suspension, please verify your details immediately. **>>> Verify Now: http://secure-account-verify.com/login** Failure to verify within 24 hours will result in a permanent account lock. Regards, Security Team

NOTE Rows highlighted in red contain confirmed phishing indicators. Detailed analysis of each indicator follows below.

Indicator Analysis Table

Each detected indicator is listed below with its category, risk weight, and a plain-language explanation of why it is suspicious.

#	Indicator	Category	Risk	Explanation
1	**Spoofed sender domain**	Sender	HIGH	secure-account-verify.com has no relation to any legitimate service. The domain name mimics a security notification but belongs to no real bank, platform, or institution.
2	**Display name / address mismatch**	Sender	HIGH	The display name reads 'Security Team' but the actual sending domain is a newly registered, unknown address — a classic impersonation technique.
3	**Generic greeting**	Content	MEDIUM	"Dear User" — legitimate services always address you by the name you registered with. A generic greeting means the sender does not know who you are.

4	**Urgency language**	Content	**MEDIUM**	"Failure to verify within 24 hours" — artificial time pressure is designed to stop you from thinking carefully or verifying the request independently.
5	**Fear-based threat**	Content	**MEDIUM**	"Permanent account lock" — threatening permanent consequences for inaction creates panic. Legitimate companies provide grace periods and multiple contact methods.
6	**Credential verification request**	Content	**HIGH**	The email asks you to "verify your details" via a link — this is credential harvesting. No legitimate company sends you to an external link to verify your account.
7	**Malicious / suspicious URL**	Link	**HIGH**	http://secure-account-verify.com/login — the domain does not match any known brand. Uses HTTP (not HTTPS), indicating no security certificate. URL was not from a verified institution.
8	**No HTTPS on login link**	Link	**MEDIUM**	All genuine financial and account-management pages use HTTPS (the padlock). An HTTP link for a login page is a definitive sign the site is not secure or legitimate.
9	**Vague threat — no account details**	Content	**MEDIUM**	A real security alert from your bank or platform would include your name, the last 4 digits of your account, the date and type of 'suspicious activity'. This email has none of these.
10	**Unusual send time**	Metadata	**LOW**	Sent at 02:14 AM — phishing campaigns are often sent in the early hours when automated filters are less active and users are less vigilant.

Table colour key: red = HIGH risk indicator, amber = MEDIUM, green/teal = LOW.

SECTION 3

Email Risk Classification

A consistent three-tier framework for classifying every email your team encounters.

Every email analyzed should be assigned one of three risk classifications. This framework ensures consistent communication between analysts, IT teams, and non-technical staff.

SAFE

No phishing indicators detected. The email appears to come from a legitimate, authenticated source.

- Sender domain matches a verified organization
- SPF, DKIM, and DMARC authentication all pass
- No urgency, fear, or social engineering language
- All links point to legitimate, HTTPS-secured domains
- Recipient addressed by their registered name

Example: A monthly newsletter from your company's HR portal, sent from @yourcompany.com with DKIM passing.

SUSPICIOUS

One or more indicators suggest the email may not be legitimate. Requires human review before any action is taken.

- Sender domain is slightly unusual but not confirmed malicious
- Generic greeting but no active malicious link found
- Urgency language present but link resolves to a known domain
- SPF soft-fail (message may be legitimate but misconfigured)
- Unusual send time or formatting inconsistencies

Example: An email from orders@amazon-help-services.org with your name in the greeting but a suspicious domain.

PHISHING

Multiple high-confidence indicators confirm this is a malicious email. Must not be interacted with. Report immediately to IT security.

- Spoofed or typosquatted sender domain
- Active malicious or credential-harvesting link

- Explicit request for password, OTP, or payment details
- SPF and DKIM both fail — email is not authenticated
- Confirmed malicious URL in threat intelligence databases

Example: The task brief sample email: spoofed domain, fake HTTP login link, credential request, urgency + fear combined.

Scoring Guide

Use this point-based system to assign a classification objectively:

Condition	Classification / Points
HIGH indicator detected (spoofed domain, malicious link, credential request, auth fail)	+3 pts each
MEDIUM indicator detected (urgency language, generic greeting, HTTP link, free email)	+2 pts each
LOW indicator detected (grammar errors, unusual send time, formatting issues)	+1 pt each
TOTAL 0–3 points	SAFE
TOTAL 4–7 points	SUSPICIOUS
TOTAL 8+ points	PHISHING
Override: any confirmed malicious payload or known malicious URL detected	Force PHISHING

RESULT

The task brief sample email scores 14 points (4 HIGH indicators x3 + 3 MEDIUM indicators x2). Classification: PHISHING — HIGH RISK. No part of this email should be interacted with.

SECTION 4

How the Attack Works

A plain-language explanation of what happens from the attacker's perspective — written for non-technical employees.

Understanding the attacker's playbook removes the mystery from phishing. Below is a step-by-step explanation of exactly what happens when a phishing attack is executed — written in plain language so any employee can understand and recognise it.

Step 1	**The attacker chooses a target** The attacker decides who to target — this could be everyone at a company (mass phishing) or a specific individual (spear phishing). They research the target using LinkedIn, company websites, and social media to make the email feel personal and believable.
Step 2	**A fake identity is created** The attacker registers a domain that looks almost identical to a trusted brand — for example, secure-account-verify.com instead of paypal.com. They then set up a fake email server and a fake login page that is visually identical to the real website.
Step 3	**The email is crafted and sent** Using psychological triggers — fear, urgency, authority — the attacker writes an email that pushes the victim to act without thinking. The email is sent from the fake domain, often in bulk to thousands of recipients at once.
Step 4	**The victim clicks the link** If the victim does not check the sender or the URL, they click the link and land on the fake login page. The page looks real. They enter their username and password — which are captured by the attacker in real time.
Step 5	**Credentials are stolen** The attacker now has the victim's login credentials. They log in to the real account, change the password to lock the victim out, and begin their attack — which could mean stealing money, sending further phishing emails from the victim's account, or selling the credentials.

Step 6	**The damage spreads** A single compromised account can give attackers access to internal systems, financial records, and the email contacts of the victim — enabling them to send convincing phishing emails to colleagues and clients using a real, trusted address.

KEY INSIGHT	The entire attack relies on the victim not pausing to verify. The single most effective defence is a one-second habit: hover over any link before clicking it. If the URL does not match the claimed sender, do not proceed.

SECTION 5

Prevention Tips for Users

Practical, actionable steps that reduce phishing risk — for both individuals and organisations.

The following tips are designed to be shared directly with employees. Each tip is written in plain language, with a concrete action and a real-world example. No technical knowledge is required to follow them.

01

Check the actual email address — not just the name

Your email client shows a friendly name like 'PayPal Security'. Always click on the name to reveal the actual email address behind it. If the address is from @gmail.com or an unfamiliar domain, treat it as suspicious.

Example: Display name: 'HDFC Bank Alert' | Actual: hdfcalert99@outlook.com → SUSPICIOUS

02

Hover before you click — every time

On desktop, hover your mouse over any link without clicking. The real destination URL appears at the bottom of your browser or email client. If that URL does not match the claimed brand, do not click.

Example: Email says: 'Verify your PayPal account' | URL shows: http://pp-secure-verify.net → DO NOT CLICK

03

Never enter credentials after clicking an email link

If any email asks you to log in, open a new browser tab and type the website address yourself. Never use a link in an email as your route to a login page — even if the email looks completely legitimate.

Example: Instead of clicking 'Sign in to your account', open a new tab and go to paypal.com directly.

04

Treat urgency and fear as red flags

Legitimate banks, governments, and platforms do not permanently lock accounts within 24 hours without also calling you. If an email is trying to make you panic — pause. That pause is your greatest defence.

Example: If you feel panic when reading an email, that is the attacker working. Stop. Breathe. Verify separately.

05	**Enable Multi-Factor Authentication (MFA) on all accounts** MFA means that even if an attacker captures your password, they still cannot access your account without a second factor — a code sent to your phone, or an authenticator app. Enable it on email, banking, and all work systems immediately. *Example: Even if your password is stolen, MFA blocks the attacker from logging in.*
06	**Verify unusual requests through a different channel** If your 'CEO' emails asking for an urgent wire transfer, or your 'IT department' asks for your password, do not reply to the email. Call the person on their known direct number to confirm. *Example: Call your CEO's mobile directly before actioning any financial request received by email.*
07	**Report suspicious emails — you are not wasting anyone's time** Every phishing email you report protects every other person in your organisation. Forward the suspicious email to your IT/security team. If no formal process exists, forward it to your manager. *Example: A single reported phishing email can stop an entire organisation-wide attack from succeeding.*
08	**Keep your software, browser, and OS updated** Many phishing attacks exploit known vulnerabilities in outdated software. Keeping everything updated closes these entry points automatically. *Example: Enable auto-updates on Windows/macOS and your browser to ensure you receive security patches.*

SECTION 6

Do's & Don'ts for Employees

A quick-reference card — suitable for printing and placing at every workstation.

This section is designed as a reference card for employees at all technical levels. Print it, share it, and post it near workstations.

DO	DON'T
✓ Always check the actual email address behind the sender's display name	✗ Never click a link in an email that asks you to log in or verify your account
✓ Hover over every link before clicking to see the real destination URL	✗ Never download an attachment you were not explicitly expecting
✓ Type website addresses manually in a new tab instead of clicking email links	✗ Never share your password, OTP, or PIN in an email — ever
✓ Verify any unusual financial or credential request by calling the person directly	✗ Never act on urgency in an email without independent verification
✓ Enable Multi-Factor Authentication (MFA) on all work and personal accounts	✗ Never trust an email's display name alone — always check the actual address
✓ Report suspicious emails to your IT or security team immediately	✗ Never open .exe, .zip, or macro-enabled Office files from unknown senders
✓ Keep your browser, email client, and operating system fully updated	✗ Never reply to a suspicious email asking for more information
✓ Look for HTTPS and a padlock icon before entering any login details	✗ Never ignore an unusual financial request just because it says it's from leadership
✓ Trust your instincts — if something feels wrong, stop and verify	✗ Never use public Wi-Fi for work email without a VPN
✓ Complete your organisation's annual phishing awareness training	✗ Never assume an email is safe just because it passed your spam filter

If You Suspect You Have Clicked a Phishing Link

1. Stop immediately.	Do not enter any information on the page that opened.
2. Disconnect from the network.	Unplug the Ethernet cable or turn off Wi-Fi on your device.

3. Do NOT turn off your computer.	Security teams need it running to investigate.
4. Call IT Security now.	Do not email — use a known direct phone number.
5. Change your passwords.	From a different, clean device — all accounts accessible from this computer.
6. Enable MFA immediately.	On all accounts if not already active.
7. Do not try to fix it yourself.	Let the security team lead the response.

This report was prepared as part of Cybersecurity Internship Task 2: Phishing Email Detection & Awareness System. All analysis, indicators, and recommendations are based on the sample email provided in the task brief and standard industry threat intelligence frameworks. This document is intended for internal educational and awareness use.